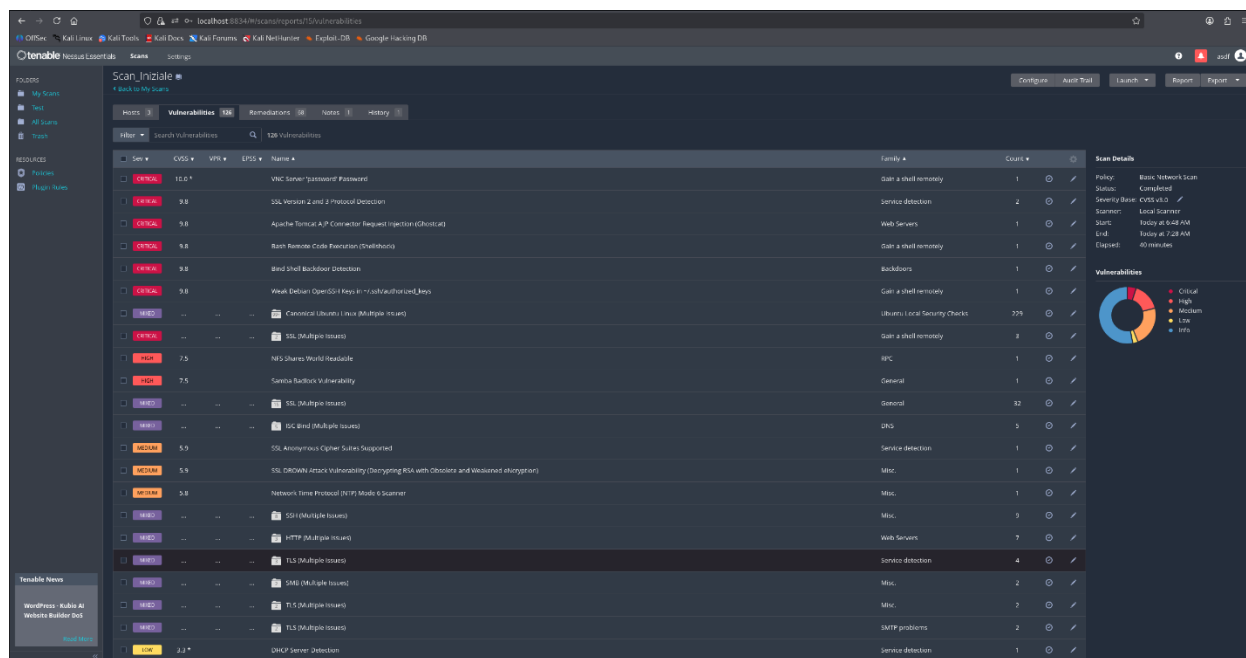


RELAZIONE TECNICA DI REMEDIATION

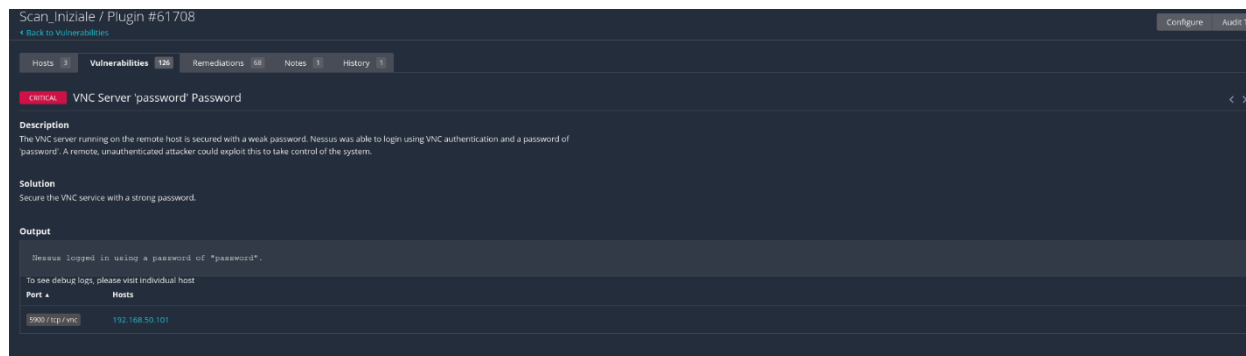
1. Introduzione e Obiettivi

A seguito della prima fase di Vulnerability Assessment, sono state identificate diverse falle di sicurezza sul target Metasploitable (IP: 192.168.50.101). L'obiettivo di questo documento è descrivere nel dettaglio le attività di eliminazione delle minacce (remediation) eseguite direttamente sul sistema.

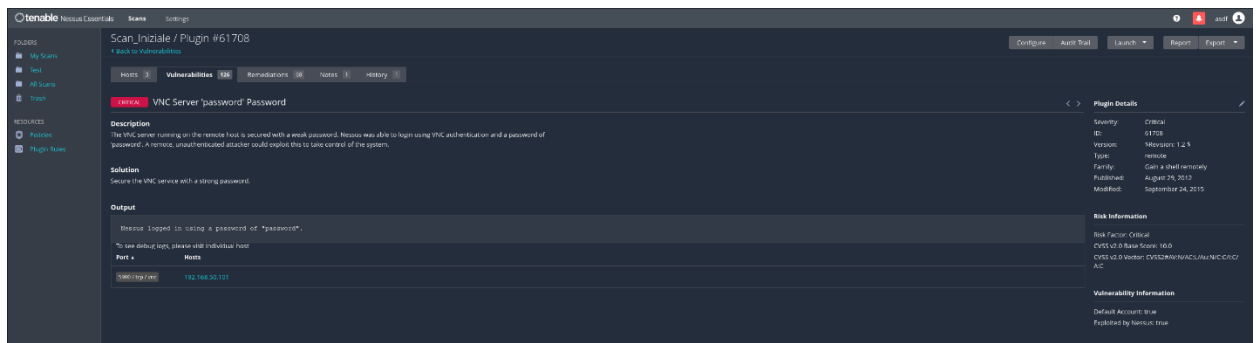
Per questa attività sono state selezionate 4 vulnerabilità critiche e ad alto impatto (punteggi CVSS compresi tra 7.5 e 10.0), applicando interventi di correzione mirati sulle configurazioni dei servizi insicuri per ridurne l'esposizione.



Vulnerabilità 1: VNC Server 'password' Password (CVSS 10.0 - Critical)



- **Descrizione del rischio:** Il servizio VNC (Virtual Network Computing) sulla porta 5900/TCP era configurato con le credenziali predefinite di sistema (password: "password"). Un attaccante remoto non autenticato poteva sfruttare questa debolezza per ottenere il controllo della macchina vulnerabile.



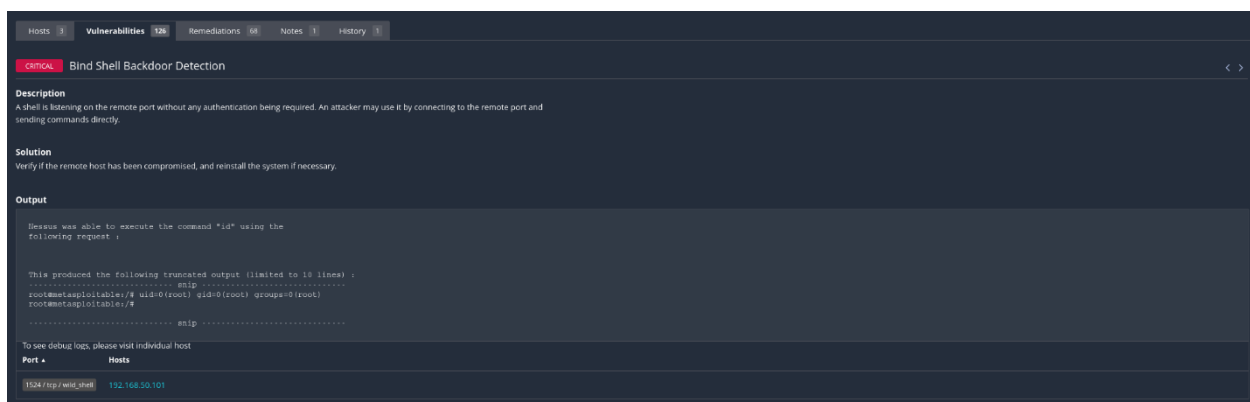
- **Procedura di Remediation:**

1. È stato effettuato l'accesso sulla macchina Metasploitable tramite la console o la shell di amministrazione.
2. È stato eseguito il comando nativo dedicato alla gestione delle credenziali VNC:

```
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$
```

3. Il sistema ha aggiornato il file di sicurezza situato nel percorso ~/.vnc/passwd. È stata digitata e confermata una nuova password robusta, eliminando la credenziale banale rilevata dal vulnerability scanner.

Vulnerabilità 2: Bind Shell Backdoor Detection - ingreslock (CVSS 9.8 - Critical)



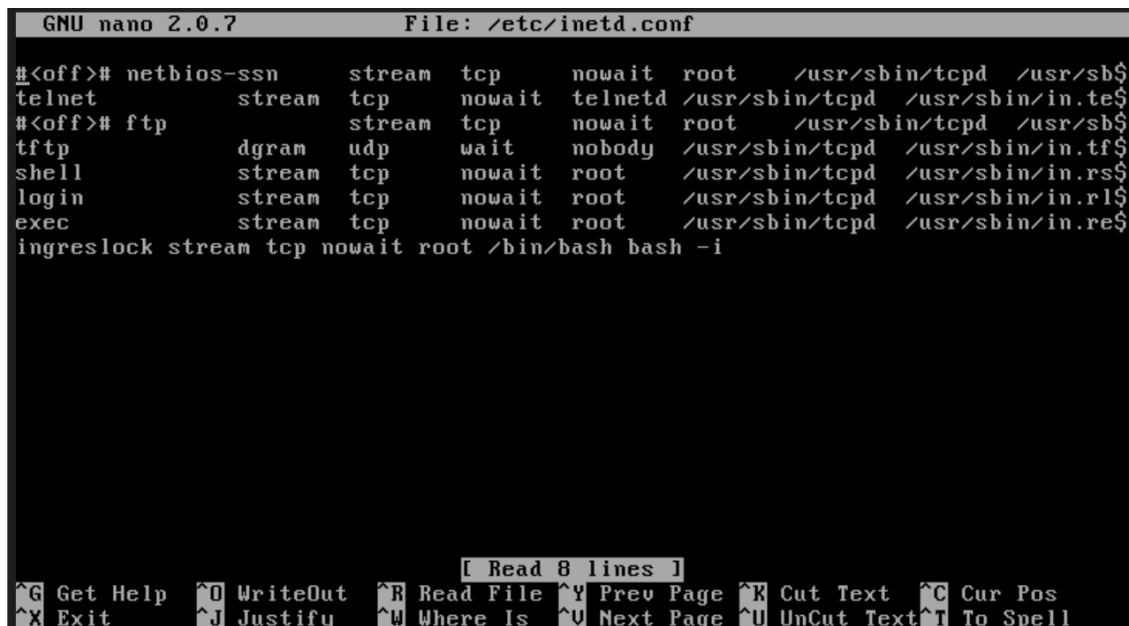
- **Descrizione del rischio:** Il super-demone di rete inetd manteneva attiva una backdoor interattiva (conosciuta storicamente come ingreslock) in ascolto sulla porta 1524/TCP. Qualsiasi host remoto poteva connettersi a questa porta senza fornire alcuna credenziale, ottenendo istantaneamente una shell interattiva con root

- **Procedura di Remediation:**

1. È stato aperto in modifica il file di configurazione globale dei servizi di rete gestiti tramite l'editor Nano:

```
sudo nano /etc/inetd.conf
```

2. È stata individuata la riga responsabile dell'attivazione della shell remota legata al servizio:
ingreslock stream tcp nowait root /bin/bash bash -i
3. La riga è stata commentata inserendo il carattere # all'inizio, disattivandone l'esecuzione al boot.



4. Per verificare l'efficacia del rimedio, è stato effettuato un test di connessione dalla macchina d'attacco Kali Linux tramite Netcat:

```
nc 192.168.50.101 1524
```



Il server ha risposto correttamente rifiutando lo scambio di pacchetti (Connection refused), confermando la chiusura della falla.

Vulnerabilità 3: Apache Tomcat AJP Connector Request Injection - Ghostcat (CVSS 9.8 - Critical)

2. Il file è stato aperto in modifica con i privilegi amministrativi necessari.
3. È stata individuata la sezione che definisce il connettore sulla porta 8009:
<Connector port="8009" protocol="AJP/1.3" ... />
4. Il blocco di codice relativo al protocollo AJP 1.3 è stato interamente commentato utilizzando i tag XML di commento (<!-- -->), isolando e disabilitando permanentemente il connettore non sicuro. Il servizio Tomcat è stato successivamente riavviato per rendere effettive le modifiche.

```

GNU nano 2.0.7      File: /etc/tomcat5.5/server.xml      Modified

                                noCompressionUserAgents="gozilla, traviata"
                                compressableMimeType="text/html,text/xml"

-->

<!-- Define a SSL HTTP/1.1 Connector on port 8443 -->
<!--
<Connector port="8443" maxHttpHeaderSize="8192"
          maxThreads="150" minSpareThreads="25" maxSpareThreads="75"
          enableLookups="false" disableUploadTimeout="true"
          acceptCount="100" scheme="https" secure="true"
          clientAuth="false" sslProtocol="TLS" />
-->

<!-- Define an AJP 1.3 Connector on port 8009 -->
<!-- <Connector port="8009"
$3" /> -->

<!-- Define a Proxyed HTTP/1.1 Connector on port 8082 -->
<!-- See proxy documentation for more information about using this. -->
<!--

^G Get Help      ^O WriteOut      ^R Read File     ^V Prev Page     ^K Cut Text       ^C Cur Pos
^X Exit          ^J Justify        ^W Where Is      ^U Next Page     ^U UnCut Text    ^T To Spell

```

Vulnerabilità 4: NFS Shares World Readable (CVSS 7.5 - High)

Scan_Iniziale / Plugin #42256

Configure

Audit Trail

Hosts

Vulnerabilities 136

Remediations 68

Notes 1

History 1

HIGH

NFS Shares World Readable

Description

The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

Solution

Place the appropriate restrictions on all NFS shares.

See Also

<http://www.tldp.org/HOWTO/NFS-HOWTO/security.html>

Output

The following shares have no access restrictions :

/ *

To see debug logs, please visit individual host

Port

Hosts

2049 / tcp / rpc.efs

192.168.50.101

- **Descrizione del rischio:** Il servizio NFS sulla porta 2049/TCP era configurato per esportare intere porzioni del file senza alcun vincolo restrittivo di rete basato su indirizzi IP o hostname * impostando inoltre l'opzione insicura no_root_squash. Questo permetteva a chiunque nella rete di montare il disco e operare con i permessi di amministrazione.

- **Procedura di Remediation:**

1. È stato analizzato e modificato il file in cui vengono definite le condivisioni dei volumi di rete della macchina tramite il comando:

sudo nano /etc/exports

```
GNU nano 2.0.7      File: /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#                to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
#_* (rw,sync,no_root_squash,no_subtree_check)
```

[Wrote 12 lines]

^G Get Help	^O WriteOut	^R Read File	^Y Prev Page	^K Cut Text	^C Cur Pos
^X Exit	^J Justify	^W Where Is	^V Next Page	^U UnCut Text	^T To Spell

2. È stata rimossa la riga permissiva o applicata una restrizione specifica per fare in modo che i file system sensibili non venissero esportati globalmente a qualsiasi host (*) disattivando l'esportazione non necessaria della root.

Considerazioni Finali

Le attività eseguite sul target Metasploitable dimostrano l'efficacia di un approccio alla sicurezza informatica. Intervenendo direttamente sulle cause alla radice ,quali credenziali predefinite, servizi obsoleti non necessari e configurazioni di rete eccessivamente permissive . è stato possibile abbattere drasticamente la superficie di attacco del sistema senza l'ausilio di soluzioni provvisorie.

In particolare ha permesso di:

- Eliminare canali di accesso diretti e non autenticati al sistema (come la disattivazione del servizio ingreslock sulla porta 1524 e la cifratura/cambio della password di VNC).
- Risanare protocolli applicativi strutturalmente esposti a vulnerabilità critiche di tipo Remote Code Execution (come il connettore AJP di Apache Tomcat).

- Impedire il rilascio massivo e non autorizzata tramite la restrizione delle condivisioni NFS

Questo processo evidenzia come il Vulnerability Management non si esaurisca nella semplice fase di identificazione delle minacce, ma richieda un ciclo continuo di analisi, remediation e successiva verifica. L'efficacia finale di questi interventi di hardening sarà documentata nel successivo report di scansione finale (ScansioneFine.pdf), in cui il confronto dei grafici evidenzierà la reale riduzione del livello di rischio complessivo della macchina target